

Semgrep Token Setup — Operator Step-by-Step

Field	Value
Revision	1
Last modified	2026-06-22T00:00:00Z
Status	active
Cross-references	Constitution.md §11.4.166, CLAUDE.md §11.4.166, docs/semgrep/CONSUMER_ONBOARDING.md, scripts/semgrep/*
Sources verified	2026-06-22 (see §7 Sources)

Table of Contents

- [1. Do you even need a token?](#)
- [2. Which token type to choose](#)
- [3. Method A — `semgrep login` \(recommended, easiest\)](#)
- [4. Method B — Web UI \(Settings → Tokens\)](#)
- [5. Make the token available to tools \(`SEMGREP\_APP\_TOKEN`\)](#)
- [6. Verify it works](#)
- [7. Sources verified](#)

1. Do you even need a token?

Short answer: the core §11.4.166 mandate does NOT need a token. The token only unlocks the Semgrep cloud / MCP features.

Capability	Token required?
<code>semgrep scan --config auto --error</code> — the local blocking scan §11.4.166 mandates (commit/push gate)	 No token. Pulls public registry rules and scans locally.
<code>semgrep login / semgrep ci</code> — Semgrep AppSec Platform managed scanning, findings dashboard, policy	 Yes — <code>SEMGREP_APP_TOKEN</code> .
Semgrep MCP server / the post-tool MCP scan hook (the one currently	 Yes — <code>SEMGREP_APP_TOKEN</code> .

Capability	Token required?
printing No SEMGREP_APP_TOKEN found, please login)	

So: the project is already §11.4.166-compliant via the tokenless local scan. You only need to follow this guide to silence the MCP hook warning and enable cloud features (centralized findings, policy, supply-chain). It is **optional but recommended**.

Token values are secrets. Per §11.4.10 they MUST NEVER be committed to git, pasted into chat, or logged. Store them only in a gitignored .env / shell profile (steps below).

2. Which token type to choose

Semgrep offers three token types:

Type	Purpose	Who creates it
CLI token	Authenticates a user running scans / publishing rules from the Semgrep CLI (semgrep ci). This is what you want for local use + the MCP hook.	Any member or admin
API token	Calls to the Semgrep REST API and third-party integrations	Admins
Service token	Auto-generated during repo onboarding for CI/CD agent auth	Automatic

➡ For this project, create a CLI token (Method A is the one-command way to get one).

3. Method A — semgrep login (recommended, easiest)

This is the fastest path — it creates a CLI token for you and stores it locally.

1. Make sure the CLI is installed (it already is on this host — semgrep --version → 1.167.0). If not: brew install semgrep (macOS) or pip install semgrep.
2. Run:

semgrep login

3. The command **opens a browser window** (or prints a link you can open manually). If you are not signed in yet, sign in / sign up (GitHub, GitLab, Google, or email).
4. In the browser **Semgrep CLI login** window, click **Activate** to authorize this machine.
5. Return to the terminal — `semgrep login` confirms success and **persists the token to `~/.semgrep/settings.yml`** automatically. After this, `semgrep ci` works on this machine with no further env setup.

If you only ever run `semgrep` on this one machine, **Method A is all you need** — the token is saved and reused. Continue to §6 [Verify](#). Do §5 only if a tool specifically reads the `SEMGREP_APP_TOKEN` env var (the MCP hook does).

4. Method B — Web UI (Settings → Tokens)

Use this if you want to create the token manually (e.g. to paste into an env var / CI secret).

1. Open <https://semgrep.dev/login> and sign in (or sign up — free Community tier is fine).
2. Go to the tokens page directly: <https://semgrep.dev/orgs/-/settings/tokens> (equivalently, in the UI: **Settings** → **Tokens**).
3. Click **Create new token**.
4. Set a **Name** (e.g. `helix-ota-local`) and select the **Token scopes** (for CLI/agent use, the **Agent (CI)** scope).
5. Click **Save**.
6. **Immediately copy the token value** (“Secrets value”) — it is shown only once. Treat it as a secret (§11.4.10).

5. Make the token available to tools (SEMGREP_APP_TOKEN)

The Semgrep MCP server and `semgrep ci` read the token from the `SEMGREP_APP_TOKEN` environment variable. Set it **without committing it**:

Option 1 — shell profile (persists across sessions, host-local):

```
# ~/.zshrc (macOS default) or ~/.bashrc — NOT in the repo
export SEMGREP_APP_TOKEN=<paste-your-token-here>
```

Then reload: `source ~/.zshrc` (or open a new terminal).

Option 2 — project `.env` (gitignored per §11.4.30/§11.4.10):

```
# .env (already gitignored — confirm with: git check-ignore .env)
SEMGREP_APP_TOKEN=<paste-your-token-here>
```

Lock it down: `chmod 600 .env`.

⚠️ Never put the token in `.env`, example, any tracked file, a commit message, or a chat message. If it ever leaks, **rotate it** at <https://semgrep.dev/orgs/-/settings/tokens> (delete + create new) per §11.4.10.

6. Verify it works

```
# 1. Confirm the env var is set (prints only that it is non-empty
    - does NOT echo the secret)
[ -n "$SEMGREP_APP_TOKEN" ] && echo "SEMGREP_APP_TOKEN is set ✅"
|| echo "NOT set ❌"
```

```
# 2. Confirm the CLI is authenticated
semgrep ci --dry-run 2>&1 | head -20      # should NOT say "No
    SEMGREP_APP_TOKEN found"
```

```
# 3. The tokenless local gate still works regardless (this is the
    §11.4.166 blocking scan)
```

```
semgrep scan --config auto --error server/ submodules/ scripts/
```

When the MCP hook stops printing `No SEMGREP_APP_TOKEN found`, please login to Semgrep, you are done.

7. Sources verified

Verified against the official Semgrep documentation on **2026-06-22** (§11.4.99):

- Access tokens (types, Settings → Tokens, create new token): <https://docs.semgrep.dev/deployment/tokens>
- Tokens settings page (UI path): <https://semgrep.dev/orgs/-/settings/tokens>
- `semgrep login` CLI flow + `semgrep ci` token usage: <https://semgrep.dev/docs/semgrep-ci/running-semgrep-ci-with-semgrep-cloud-platform/>
- CI environment variables (`SEMGREP_APP_TOKEN`): <https://semgrep.dev/docs/semgrep-ci/ci-environment-variables>
- Login page: <https://semgrep.dev/login>